SOC L1 LAB · INC-002

Reproduction Guide — INC-002 Lab

Rebuilding the rogue-account scenario and its detection

INCIDENT	INC-002 — Rogue local account added to sudo
REPORT DATE	2026-10-31
CLASSIFICATION	Lab exercise — sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	High

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. Prerequisites
2. Part A — Verify the base
3. Part B — Deploy the INC-002 rules
4. Part C — Validate the rule before the incident
5. Part D — Start legitimate noise
6. Part E — Clean state
7. Part F — Run the incident
8. Part G — Verify and export
9. Part H — Cleanup
10. Troubleshooting
11. Checklist

This guide reproduces INC-002 on the existing lab. It assumes the Wazuh stack and the Debian endpoint from INC-001 are running. If you are starting from a bare host, build those first with `writeups/INC-001/02-reproduction-guide.md`, then return here.

Time: 20–30 minutes if the base lab is up. **Result:** a rogue local account added to `sudo`, the custom rule firing during the action, and a complete evidence set.

---

1. Prerequisites

Requirement	Check
Wazuh stack running	`docker compose ps` shows manager, indexer, dashboard
Agent active	`agent_control -l` shows `001 soc-victim Active`
auditd keys	`auditctl -l` shows `audit-wazuh-c` and `audit-wazuh-w`
FIM realtime on `/etc`	`grep -A6 '<syscheck>' /var/ossec/etc/ossec.conf`
Admin sudo	`analyst` can run `sudo -n true`
Rule mount	`rules/` mounted at `/var/ossec/etc/rules`

Set variables:

```
export LAB="$HOME/Documents/Eterna/soc-l1-lab"
export VMKEY="$LAB/lab/vm/keys/id_ed25519"
export VM="analyst@127.0.0.1"
export VMPORT=2222
```

---

2. Part A — Verify the base

```
docker ps --format '{{.Names}}\t{{.Status}}'
ssh -i "$VMKEY" -p "$VMPORT" -o StrictHostKeyChecking=no "$VM" \
  'systemctl is-active wazuh-agent auditd; sudo auditctl -l | grep -E "audit-wazuh-[cw]"'
```

Expected:

```
active
active
-w /etc/passwd -p wa -k audit-wazuh-w
...
-a always,exit -F arch=b64 -S execve -F key=audit-wazuh-c
```

Check FIM coverage:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo grep -A8 "<syscheck>" /var/ossec/etc/ossec.conf | head -12'
```

`/etc` must have `realtime="yes"`.

---

3. Part B — Deploy the INC-002 rules

The manager mounts the repository's `rules/` directory. Mount the **directory**, not a single file; a single-file bind mount follows the inode and stops seeing edits when the file is replaced.

```
volumes:
  - /home/luqman/Documents/Eterna/soc-l1-lab/rules:/var/ossec/etc/rules:ro
```

Deploy:

```
cd "$HOME/wazuh-docker/single-node"
docker compose up -d wazuh.manager
sleep 20
for id in 100121 100122 100123 100124 100125 100126; do
  printf '%s: ' "$id"
  docker exec single-node-wazuh.manager-1 \
    grep -c "id=\"$id\"" /var/ossec/etc/rules/local_rules.xml
done
```

Expected: `1` for each. The deployed file is `rules/local_rules.xml`; the rationale and test matrix are in `rules/inc-002-rules.md`.

---

4. Part C — Validate the rule before the incident

Use a throwaway account so the real run starts clean.

```
ssh -i "$VMKEY" -p "$VMPORT" -o StrictHostKeyChecking=no "$VM" '
sudo useradd -m -s /bin/bash svc-test
echo "svc-test:Summer2026!" | sudo chpasswd
sudo usermod -aG sudo svc-test
id svc-test'
sleep 8
docker exec single-node-wazuh.manager-1 sh -c \
  'grep "\"id\":\"100121\"" /var/ossec/logs/alerts/alerts.json | tail -1' \
  | python3 -c '
import sys, json
a=json.loads(sys.stdin.read())
print(a["timestamp"], a["rule"]["description"])
```

```
print(a["data"]["audit"]["execve"])
'
```

Expected:

```
Privilege assignment: user added to the sudo group (svc-test)
{'a0': 'usermod', 'a1': '-aG', 'a2': 'sudo', 'a3': 'svc-test'}
```

Clean up the test account:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo gpasswd -d svc-test sudo
sudo userdel -r svc-test'
```

If this does not fire, stop and use §10 before running the incident. A rule that has never fired is not a control.

---

5. Part D — Start legitimate noise

The scenario is more realistic if routine admin activity is present. This loop logs in every 30 seconds, runs `uptime`, and performs a `sudo systemctl` call.

```
cat > /tmp/noise.sh <<EOF
#!/usr/bin/env bash
KEY=$VMKEY
END=\$1
while [ "\$(date +%s)" -lt "\$END" ]; do
  ssh -i "\$KEY" -p $VMPORT -o StrictHostKeyChecking=no \
      -o UserKnownHostsFile=/dev/null -o BatchMode=yes "$VM" \
      'uptime -p; systemctl is-active nginx' >/dev/null 2>&1
  ssh -i "\$KEY" -p $VMPORT -o StrictHostKeyChecking=no \
      -o UserKnownHostsFile=/dev/null -o BatchMode=yes "$VM" \
      'sudo -n systemctl is-active nginx' >/dev/null 2>&1
  sleep 30
done
EOF
chmod +x /tmp/noise.sh
END=$(( $(date +%s) + 180 ))
setsid /tmp/noise.sh "$END" >/dev/null 2>&1 &
```

---

6. Part E — Clean state

Before the run, confirm the incident account does not exist and note the expected `sudo` members:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
getent passwd svc-ops || echo "svc-ops absent"
getent group sudo'
```

Expected:

```
svc-ops absent
sudo:x:27:analyst,debian
```

Take a snapshot if you want to return to this exact point:

```
cd "$LAB/lab/vm"
./snapshot.sh save pre-inc002
```

---

7. Part F — Run the incident

Follow `04-attack-setup.md`. In short:

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo useradd -m -s /bin/bash svc-ops
echo "svc-ops:Summer2026!" | sudo chpasswd
sudo usermod -aG sudo svc-ops
id svc-ops'
```

Record the start and action times in UTC. Wait 60–90 seconds for the alert pipeline.

---

8. Part G — Verify and export

8.1 Expected detections

```
for id in 100121 5902 5901 550 80792; do
  echo "== $id =="
  docker exec single-node-wazuh.manager-1 \
    grep "\"id\":\"$id\"" /var/ossec/logs/alerts/alerts.json | tail -1 \
    | jq -r '[.timestamp,.rule.id,.rule.description] | @tsv'
done
```

Expected:

```
100121  Privilege assignment: user added to the sudo group (svc-ops)
5902    New user added to the system.
5901    New group added to the system.
```

```
550     Integrity checksum changed.
80792   Audit: Command: /usr/sbin/usermod.
```

8.2 Export the window

```
docker exec single-node-wazuh.manager-1 cat /var/ossec/logs/alerts/alerts.json \
  > /tmp/alerts_all.json

python3 - <<'PY'
import json, datetime
start = datetime.datetime.fromisoformat("2026-10-31T04:30:40+00:00")
end   = datetime.datetime.fromisoformat("2026-10-31T04:32:00+00:00")
rows=[]
for line in open('/tmp/alerts_all.json'):
    try: a=json.loads(line)
    except: continue
    if a.get('agent',{}).get('name')=='soc-victim' and \
       start <= datetime.datetime.fromisoformat(a['timestamp']) <= end:
        rows.append(a)
json.dump(rows, open('docs/evidence/INC-002-alerts.json','w'), indent=1)
print(len(rows), "alerts")
PY
```

8.3 Export the account records

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'sudo journalctl --since "2026-10-31 04:30:40" --until "2026-10-31 04:31:20" --no-pager \
   | grep -Ei "useradd|usermod|chpasswd|new user|new group|sudo:"' \
  > docs/evidence/INC-002-account.log

ssh -i "$VMKEY" -p "$VMPORT" "$VM" \
  'getent group sudo; getent passwd svc-ops' \
  > docs/evidence/INC-002-membership.txt
```

Decode the command trail with the audit helper in `writeups/INC-001/02-reproduction-guide.md` §7.4, changing the time window to 04:30:46–04:30:50 and the UID filter to `uid=1000`.

---

9. Part H — Cleanup

```
ssh -i "$VMKEY" -p "$VMPORT" "$VM" '
sudo gpasswd -d svc-ops sudo
sudo userdel -r svc-ops
getent group sudo
getent passwd svc-ops || echo "svc-ops removed"'
```

Expected:

```
sudo:x:27:analyst,debian
svc-ops removed
```

If you took the snapshot:

```
cd "$LAB/lab/vm"
./snapshot.sh load pre-inc002
```

---

10. Troubleshooting

Symptom	Cause	Fix
100121 never fires	Rule not loaded	Check `grep 100121` in the container; recreate the manager
100121 loaded but silent	auditd key missing	Ensure `-a always,exit -F arch=b64 -S execve -k audit-wazuh-c` is loaded
100121 silent for a custom group	Rule hard-codes `sudo`	Add the group name or a CDB list
100121 silent after `/etc/group` edit	Rule matches `usermod`, not file edits	Use FIM 550 plus a membership baseline; the rule is not designed for this
Only 5901/5902 fire	Custom rule missing or stale	Check the mount, restart the manager, re-run the validation
Rule edits appear not to apply	Single-file bind mount and inode replacement	Mount the `rules/` directory and recreate the container
`userdel -r` fails	The account still has a session	`pkill -KILL -u svc-ops`, then delete
`sudo -l -U` fails	It wants a TTY	Use `sudo -l -U svc-ops` in an interactive shell, or skip it
FIM alerts appear before audit alerts	FIM events are batched; audit events are grouped	Use the journal for action times, alerts for detection times
5902 is "only" level 8	Stock severity	That is the gap 100121 fills; do not lower it, add context

---

11. Checklist

- [ ] Agent `001` active
- [ ] auditd keys `audit-wazuh-c` and `audit-wazuh-w` loaded
- [ ] `/etc` in FIM realtime
- [ ] Rule 100121 visible in the container
- [ ] Validation account produced 100121, then was removed
- [ ] `svc-ops` absent before the run

- [ ] Noise generator running
- [ ] Action produces 100121, 5902, 5901, 550, 80792
- [ ] Evidence files written
- [ ] Account removed and `sudo` membership restored